

API Attacks

CompTIA PenTest+ (PT0-003)

Domains:

- 3.0: Vulnerability Discovery and Analysis
- 4.0: Attacks and Exploits

Objectives:

- 3.1: Given a scenario, conduct vulnerability discovery using various techniques.
- 4.5: Given a scenario, perform web application attacks using the appropriate tools.
- 4.10: Given a scenario, use scripting to automate attacks.

Video Overview

This video provides an understanding of API attacks, a growing concern in cybersecurity. By exploring different types of APIs and common attack methodologies, you'll gain practical insights into identifying and mitigating vulnerabilities. This knowledge is directly applicable to real-world penetration testing scenarios and is vital for securing modern web applications, ultimately preparing you for a successful career in cybersecurity.

Key Topics Covered

- API Fundamentals: How different software systems communicate and the significance of APIs as an attack vector.
- SOAP APIs: Understanding Simple Object Access Protocol, its use of XML and WSDL files, and vulnerabilities like Command Injection and SQL Injection.
- REST APIs: Exploring Representational State Transfer, its use of HTTP methods and JSON, and susceptibility to SQL Injection.
- XML-RPC: Identifying this older API type in WordPress installations and its use in brute-force, Denial of Service (DDoS), and Server-Side Request Forgery (SSRF) attacks.
- Attack Tools and Techniques: Using Burp Suite (with Whistler extension) for capturing and manipulating requests, and WPScan for automating brute-force attacks.

- Injection Techniques: Practical application of Command Injection (e.g., ; `ls -la`) and SQL Injection (e.g., ' `OR 1=1 --`) in both SOAP and REST APIs.
- Server-Side Request Forgery (SSRF): How an API server can be leveraged as a proxy to request internal or external resources, bypassing firewalls and scanning internal ports.

Student Notes Section (Optional)